

Data Leak Analysis

Reviewing a least-privilege failure using NIST SP 800-53: AC-6

Project Description

For this activity, I looked into a data leak at an edtech company where internal business documents ended up posted on social media. I worked through what caused the leak, reviewed the relevant NIST SP 800-53 control (AC-6, Least Privilege), and came up with two control enhancements that could have prevented it, along with reasoning for why they'd help.

Issue(s)

The leak happened because a manager gave a customer success rep access to a folder of internal documents and forgot to remove that access afterward. During a sales call, the rep meant to share one marketing file but accidentally shared a link to the entire folder, and the business partner posted it publicly.

Review

NIST SP 800-53's AC-6 control is about enforcing least privilege — making sure people only get the access they actually need to do their job, and nothing more. It includes several control enhancements, like periodically reviewing who has access to what and logging when privileged access is used, so unnecessary or forgotten permissions can be caught and removed.

Recommendation(s)

- 1) AC-6(7) – Review of User Privileges: Set up a recurring review of who has access to shared folders and files, so access that's no longer needed (like the manager's forgotten share) gets caught and removed before it becomes a problem.
- 2) AC-6(9) – Log Use of Privileged Functions: Log and monitor activity around shared folders and links, especially when something is shared outside the company, so unusual sharing gets flagged quickly instead of going unnoticed.

Justification

A regular access review would have caught the manager's unshared folder before it turned into a risk, and logging shared-link activity would have flagged the moment the rep sent the wrong link externally. Together, these two enhancements close the gap that let the leak happen without anyone noticing until it was already public.